

S11/L3

Esercizio OllyDBG

Traccia

Fate riferimento al malware: Malware_U3_W3_L3, presente all'interno della cartella Esercizio_Pratico_U3_W3_L3 sul desktop della macchina virtuale dedicata all'analisi dei malware. Rispondete ai seguenti quesiti utilizzando OllyDBG.

- 1) All'indirizzo 0040106E il Malware effettua una chiamata di funzione alla funzione «CreateProcess». Qual è il valore del parametro «CommandLine» che viene passato sullo stack?
- 2) Inserite un breakpoint software all'indirizzo 004015A3. Qual è il valore del registro EDX? Eseguite a questo punto uno «step-into». Indicate qual è ora il valore del registro EDX motivando la risposta. Che istruzione è stata eseguita?
- 3) Inserite un secondo breakpoint all'indirizzo di memoria 004015AF. Qual è il valore del registro ECX? Eseguite uno step-into. Qual è ora il valore di ECX? Spiegate quale istruzione è stata eseguita.

BONUS: spiegare a grandi linee il funzionamento del malware

1) Parametro CommandLine

Nella Disassembler Window di OllyDBG troviamo l'indirizzo di memoria 0040106E (per farlo basta usare la funzione di ricerca tramite il comando alt+g) ed impostiamo un breakpoint.

0040106E | . FF15 04404000 CALL DWORD PTR DS:[&KERNEL32.CreateProcessA] | **CreateProcessA**

La sezione commenti presente nella Disassembler Windows mette a disposizione una serie di informazioni sul processo creato.

```
pProcessInfo
{
  pStartupInfo
  CurrentDir = NULL
  pEnvironment = NULL
  CreationFlags = 0
  InheritHandles = TRUE
  pThreadSecurity = NULL
  pProcessSecurity = NULL
  CommandLine = "cmd"
  ModuleFileName = NULL
  CreateProcessA
```

Tra queste informazioni troviamo il valore di «*CommandLine*», ovvero **cmd**.

2) Registro EDX

Impostiamo un software breakpoint (chiamato «toggle» all'interno di OllyDBG) con il tasto destro sull'istruzione presente all'indirizzo 004015A3.

004015A3 | . 33D2 | XOR EDX,EDX

Nel Register Windows di OllyDBG possiamo vedere il valore del registro EDX.

```
Registers (FPU)
EAX 1DB10106
ECX 7EFDE000
EDX 000010B1
EBX 7EFDE000
ESP 0018FF5C
EBP 0018FF88
ESI 00000000
EDI 00000000
EIP 004015A3 Malware_.004015A3
```

Usiamo la funzione «step-into» (attivabile con questo pulsante ) di OllyDBG per analizzare più facilmente il codice. Dopo aver eseguito l'istruzione presente all'indirizzo 004015A3 notiamo che il registro EDX ha cambiato valore.

Registers (FPU)	
EAX	1DB10106
ECX	7EFDE000
EDX	00000000
EBX	7EFDE000
ESP	0018FF5C
EBP	0018FF88
ESI	00000000
EDI	00000000

Il motivo di questa modifica è dovuta all'operazione di tipo XOR che il malware ha eseguito. Infatti, fare uno XOR dello stesso oggetto dà sempre come risultato 0.

3) Registro ECX

Come già fatto nei punti precedenti, troviamo e impostiamo un breakpoint all'indirizzo d'interesse (in questo caso 004015AF).

004015AF | . 81E1 FF000000 AND ECX.0FF

Prima di eseguire l'istruzione, vediamo che il registro ECX ha il seguente valore

Registers (FPU)	
EAX	1DB10106
ECX	1DB10106
EDX	00000001
EBX	7EFDE000
ESP	0018FF5C
EBP	0018FF88
ESI	00000000
EDI	00000000



Attiviamo la modalità «step-into» e osserviamo come cambia il registro.

Registers (FPU)	
EAX	1DB10106
ECX	00000006
EDX	00000001
EBX	7EFDE000
ESP	0018FF5C
EBP	0018FF88
ESI	00000000
EDI	00000000

Perché questo cambiamento? Perché viene eseguita sul registro un'operazione di tipo AND.

Possiamo verificare la veridicità dell'operazione riproducendola a mano.

Prima dell'istruzione abbiamo i seguenti valori esadecimale:

ECX = 1DB10106

Valore usato per l'AND = 0FF

In binario abbiamo:

ECX = 11101101100010000000100000110

0FF = 11111111

Andando a fare l'operazione di AND otteniamo

ECX: 11101101100010000000100000110

0FF: 000000000000000000000011111111

Risultato: 00000000000000000000000000110

Il valore 110 in esadecimale è pari a 6, che è effettivamente il risultato ottenuto nel registro dopo l'operazione di AND.

BONUS

Funzionamento del malware

Analizzando il codice vediamo che malware effettua alcuni macro-step usando le seguenti funzioni.

- **CreateProcess con CommandLine impostato a "cmd":**
Questa funzione viene utilizzata per creare un nuovo processo e il parametro CommandLine è impostato su "cmd".
- **WSASocket:**
WSASocket è una funzione della Windows Sockets API (WinSock) che crea un socket, che è essenziale per stabilire una connessione di rete. In questo caso, viene usata per creare un socket TCP con IPv4.
- **gethostbyname:**
Questa funzione viene utilizzata per risolvere i nomi di dominio in indirizzi IP.
- **getCommandLine:**
getCommandLine restituisce il comando che è stato utilizzato per avviare il processo corrente.

Conclusioni

È ragionevole ipotizzare che il malware tenti di lanciare una reverse shell. Questo perché possiamo osservare la creazione di una nuova istanza della shell di comando di Windows (cmd.exe), e di un socket connesso verso un IP risolto tramite la funzione «gethostbyname». Probabilmente, la connessione avviene verso un server di controllo (C2, Command and Control) dell'attaccante.